



Blockchain Commons

***Advocating for the Creation of Open, Interoperable,
Secure, and Compassionate Digital Infrastructure***

Blockchain Commons #Gordian Meeting 2026-10-07



What is Blockchain Commons?

- We are a community interested in self-sovereign control of digital assets.
- We bring together stakeholders to collaboratively develop interoperable infrastructure.
- We design decentralized solutions where everyone wins.
- We are a neutral "not-for-profit" that enables people to control their own digital destiny.

Thank you to our Sponsors!

 **Bitmark**

chia

 **CROSSBAR**



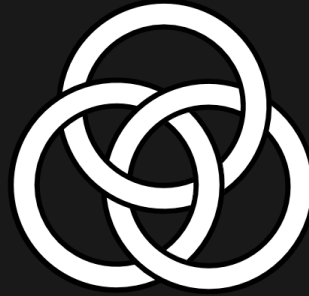
 **FOUNDATION**

 **Human
Rights
Foundation**

 **unchained
capital**

 **Zcash**
Community Grants

Become a sponsor! Mail us at team@blockchaincommons.com

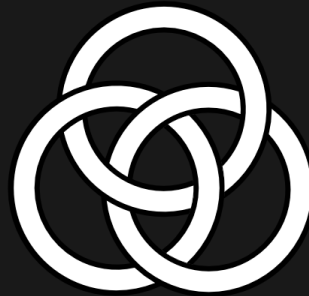


Last Meeting

Bitcoin Interoperability & Resilience

<https://developer.blockchaincommons.com/meetings/2026-08-resilience/>

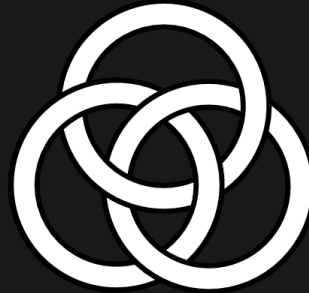




Today's Topics

- Cloudflare Passkeys
- Agentic AI & Security

Cloudflare Passkeys

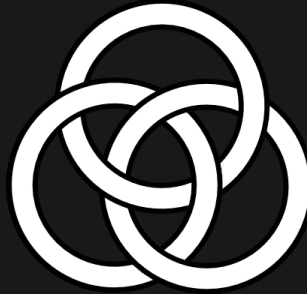


passkey-cloudflare

- Passkey-Only Identity
- Built on Cloudflare Workers & Durable Objects
- For Collaborative Web Apps



<https://github.com/BlockchainCommons/passkey-cloudflare>



What Was the Intent?

- Want to Improve Auth Diversity
 - Go Beyond the Apple/Google Ecosystem!
 - Passkeys Can Even Bootstrap Biometrics
 - Needed for Projects Like Collaborative Seed Recovery
- Piggyback on a Secure Server
 - Don't Have To Trust a Small Library
- Piggyback on Robust Recovery

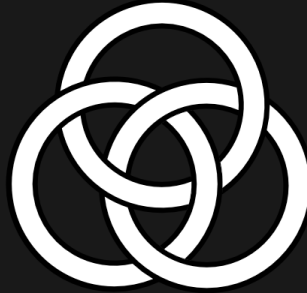


Core Functionality

- Passkey verifies identity
- Application determines permissions
- User can hold several Passkeys
- Operates on Cloudflare Worker Paid
- Demo Available

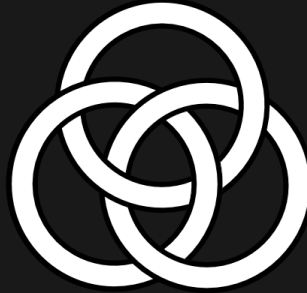


<https://passkeydemo.gordianstack.com/>



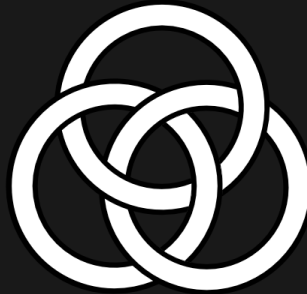
Passkey Design Principles: Registration

- A new user handle for every ceremony.
- One refusal for every failure.
- Plural passkeys from the first registration.
- Recovery codes are stored only as hashes.



Passkey Design Principles: Usage

- Identity separate from permission.
- No fallback to a weaker credential.
- Step-up for what can lock the owner out.
- Operators see state and counts, not device detail.



Gordian Technology

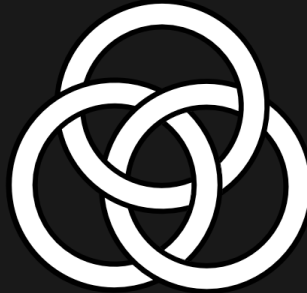
- Simple Design!
- Written with Typescript libraries.
- ByteWords label passkeys.
- ur:seed encodes recovery codes.
 - 128 bits, CRC, can be sharded (SSKR).

Repos in the Age of Agentic AI



Repos in the Age of Agentic AI

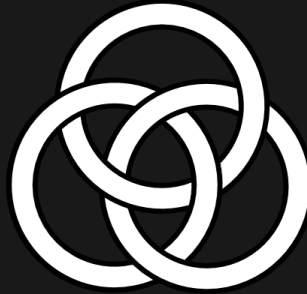
- Recognizing AI changes in coding;
- Maintaining security; and
- Being transparent about our choices



AI is Changing Coding

We must use AI to protect against AI.

- AI agents **write** code: more, faster, uneven quality
- AI agents **review** code: cheap, uneven, rarely disclosed
- AI agents **attack** code: vulnerabilities exploited at scale
- AI agents **dump out** vulnerability reports, many invalid



Disclosure, Signing, and Open Integrity

How do we credit AI work? How should we?

- How should we do **code signing, versions, and tags** when human security audits are unaffordable?
- How do we disclose **who (or what)** reviewed a project's security?
- What **standards** would we like to see emerge for the content and security of repositories?



The First Step? Git Improvements

In today's Git repos ...

- Author and committer names are **unverified text**: anyone can claim to be anyone.
- Signing is **optional**, and unsigned work merges silently.
- History can be **rewritten**, including the very first commit.
- Nothing ties a clone to **who started the repository**.
- Trust lives in the **hosting platform's** accounts and settings, not in the repository.



Open Integrity Seeks to Resolve These Issues

Open Integrity offers ...

- Immutable proof of origin
- Signed commits and tags
- Tamper detection
- Trust delegation from the inception key
- Platform-agnostic validation: GitHub, GitLab, self-hosted



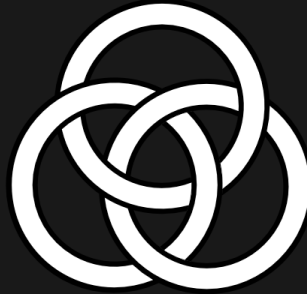
The Inception Commit: A Root of Trust

- The repository's **first commit is empty**: no files at all
- It is **signed** with the founder's SSH key
- Its committer name **is that key's fingerprint**
- Its message states the rules: **who may add signers and how**



Long-Term Support: A Chain of Trust

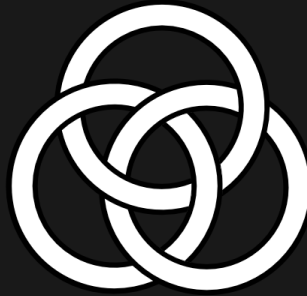
- **Signers files** in the repository list which keys may sign what
- The inception key **signs the first list**
- Every later change to a list must be signed by a key **already on it**
- Each commit is judged by the list **as of its parent**, so no key can authorize itself
- Keys can be **added, rotated, limited by date, and given roles**



Signatures Got Cheap

But how do we extend open integrity to the AI future?

- An agent can sign a thousand plausible commits a day
- A valid signature says **which key** made a commit
- It says nothing about **whether anyone competent looked**
- The scarce thing is no longer authorship: it is **accountable review**



A Proposal: Adoption Tiers

Tier	Signed	Proves	Web edits
0: Anchor	Inception commit	Where it began	Yes
1: Checkpoints	Version tags	Versions maintainers support	Yes
2: Disclosure	Review statement	Level of review	Yes
3: Full chain	Every commit w/roles	Who wrote & approved each change	No



Review Disclosure

A signed statement bound to each release:

- **Who:** Reviewer was person, AI system/model, or both
- **What:** What was reviewed or excluded
- **How:** Reading, tests, fuzzing, static analysis, AI review
- **Findings:** What was done with results
- **What is Not Claimed:** "no human security audit" is fine
- **Where to Report:** For problems, issues

An AI reviewer can sign its own statement under an agent key, but a maintainer must sign a tag that adopts it.



What We Have Built So Far

- A verifier for every commit and tag against the repository's signers files
- Roles: agents may author; only hardware-backed human keys may change main, tags, or trust files
- Claude Code agents, local and cloud, sign their own commits as themselves
- A human approves each merge with Touch ID

That is Tier 3, and it is heavy. Tiers 1 and 2 are next.



Questions for the Group

- What should a review statement **have to** say? What is optional?
- How should AI reviewers be **identified**: product, model, version, instructions?
- Should **AI-generated vulnerability reports** be labeled, and by whom?
- What does a version tag **promise** when no human audited the code?
- Which existing standards should this **build on** rather than reinvent?
- Who would **try Tier 2** on a real project?

Links

Open Integrity



OI Repo





www.BlockchainCommons.com



Christopher Allen (@ChristopherA)